使用する前に

Black Duck SCA 2026.7.0

目次

1. 概要 Black Duck..... 3

2. ログイン: Black Duck.....5

3. コードのスキャン..... 7

4. BOMの表示.....8

1. 概要 Black Duck

Black Duck は、お客様のセキュリティをサポートする包括的なサービスとツールのスイートを提供します。セキュリティを始めたばかりのお客様から、確立されたプログラムを強化するお客様まで、Black Duck は成功に必要な専門知識、スキル、製品を備えています。



Black Duck SCAについて

Black Duck SCAはソフトウェア構成分析（SCA）ソリューションであり、組織はコードベース内のオープンソースコンポーネントを特定、追跡、管理できるようになります。自動ライセンスコンプライアンス、セキュリティの脆弱性検出、リスク評価が用意されているため、チームはソフトウェアのセキュリティと整合性を確保できるようになります。

主な機能

- オープンソース管理：プロジェクトでオープンソースコンポーネントを特定して追跡します。
- 脆弱性検出：National Vulnerability Database（NVD）とBlack Duck Security Advisories（BDSA）を使用し、セキュリティの脆弱性を自動でスキャンします。

- ライセンスコンプライアンス：オープンソースライセンスを分析し、企業ポリシーへのコンプライアンスを確保します。
- リスク評価とポリシー強制：セキュリティ、法的、運用上の各リスクを軽減するポリシーを定義して強制します。
- SBOMの生成：SBOMを生成・管理し、ソフトウェアの依存関係に対する透明性を維持します。

Black Duck SCAの仕組み

- コードのスキャン：Black Duckスキャンツール（Detect、統合、またはAPI）を使用し、コードベースを分析します。
- コンポーネントの特定： Black Duck では、コードの依存関係は、KnowledgeBase（KB）内にある既知のオープンソースライブラリにマッピングされます。
- リスクの評価： Black Duck では、セキュリティの脆弱性、ライセンスの問題、ポリシー違反がチェックされます。
- 対処：レポートを表示し、リスクに優先順位を付け、修正を適用し、コンプライアンスに準拠するSBOMを生成します。

まず初めに

1. アカウントの設定：Black Duckインスタンスまたはクラウドホスト環境にログインします。
2. 最初のスキャンを実行：サンプルプロジェクトを分析し、結果をレビューします。
3. 結果のレビュー：UIの脆弱性、ライセンスリスク、ポリシー違反を確認します。

Black Duck SCAを利用してみる

- Detectを使用するスキャンの実行方法
- 脆弱性レポートについて
- ポリシー違反の管理
- SBOMの生成

次のステップ

Black Duckの基本に慣れたら、以下のコミュニティリソースを参考に、高度な機能と技術構成も利用してみましょう。

- インターフェイスの操作
- スキャン結果の活用
- Black Duckの技術仕様
- 詳細：ドキュメントとトレーニングの各リソースをご覧ください。

2. ログイン: Black Duck

Black Duck SCAにアクセスするには、ブラウザからログインする必要があります。ログインすると、プロジェクトデータにアクセスできます(チームと組織に限定されている可能性のあるプロジェクトを含む)。

注: 有効なログイン認証情報が必要になります。ユーザー名またはパスワードがない場合は、Black Duck管理者にお問い合わせください。

ログインオプション

組織が認証を構成した方法により、以下を使用してログインできる場合があります。

- ローカルBlack Duck認証情報:管理者作成のユーザー名とパスワード。
- LDAP認証情報:組織のディレクトリサービスログイン(LDAPが有効になっている場合)。
- SAMLベースのシングルサインオン(SSO):自社のログインプロバイダーにリダイレクトされる場合があります(SAMLが構成されている場合)。

注: 多要素認証(MFA)が有効になっていても、適用されるのはローカル認証情報でログインするユーザーのみです。SAMLまたはLDAPで認証するユーザーには、MFAは適用されません。

どの方法が適用されるかわからない場合は、管理者にガイダンスをお問い合わせください。

ログイン手順

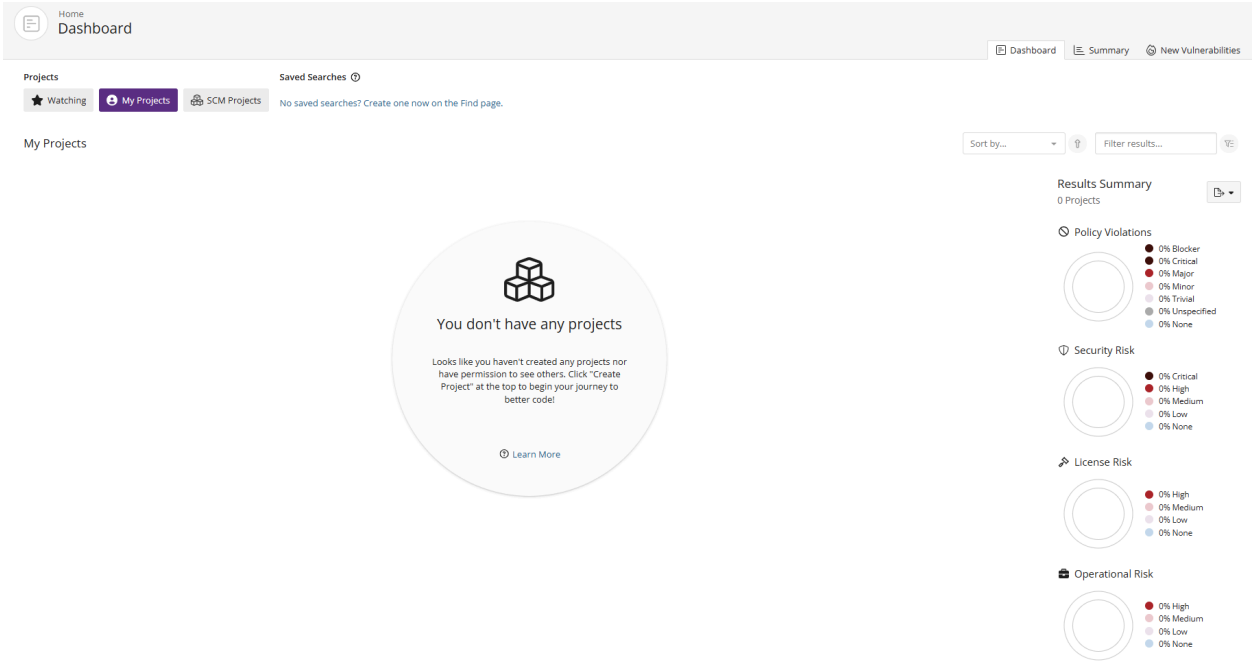
1. ブラウザを開き、システム管理者から提供されるBlack DuckのURLに移動します。通常、URLは以下の形式になります。

   ```
   https://<your-black-duck-server-hostname>
   ```

2. ユーザー名とパスワードを入力します。
   - パスワードでは大文字と小文字が区別されます。
   - 初回ログインまたはパスワードがシステムのセキュリティ要件を満たしていない場合は、パスワードの変更を求められます。画面上のパスワードルールに従い、更新を完了します。
3. [ログイン]をクリックします。
4. インスタンスでMFAが有効になっている場合は、初回ログイン時に構成するように求められます。
   - QRコードが表示されます。
   - サポート対象認証アプリ(Google Authenticatorなど)で、QRコードをスキャンします。
   - アプリに表示される6桁のコードを入力し、セットアップを完了します。

ログイン後

初回ログイン後は、空のダッシュボードにリダイレクトされます。



ダッシュボードにデータを入力するには、コードをスキャンしてプロジェクトバージョンにマッピングする必要があります。これらの手順については、当ガイドの次のセクションで説明します。

デフォルトでは、ダッシュボードには以下が表示されます。

- マイプロジェクト: 自分が作成した、または自分に割り当てられているプロジェクト。
- ウォッチ: 監視するためにマークしたプロジェクトまたはコンポーネント。

また、目的の特定プロジェクト、バージョン、またはコンポーネントの検索設定を保存することで、カスタムダッシュボードの作成もできます。保存した検索設定はダッシュボードに表示されるため、すぐに利用できます。

3. コードのスキャン

スキャンは、Black Duck SCAによってコードベース内にあるオープンソースコンポーネント、ライセンス、既知の脆弱性を識別する主な方法です。スキャンを実行すると、Black Duck SCAによってプロジェクトファイルが分析されて包括的なBOMが生成されるため、コンプライアンス、安全、最新情報を維持できるようになります。

Black Duck SCAスキャンで行われること

Black Duck ではコードベースをスキャンし、以下を行います。

- オープンソースコンポーネントとそのバージョンの特定
- ソース（National Vulnerability Database（NVD）やBlack Duck Security Advisories（BDSA）など）を使用し、既知のキュリティ脆弱性を検出
- ライセンス上のリスクとコンプライアンスを評価
- 監査・レポート作成用にBOMを生成
- 組織のリスク許容度に基づき、カスタムポリシーを強制

Black Duck SCAの統合方法に応じ、開発中、CI/CDパイプライン内、または手動でスキャンをトリガーさせることができます。

利用可能なスキャンツール

Black Duck では、さまざまな環境とワークフローに対応するさまざまなツールが用意されています。

- SCMオンボーディングUI

  SCMオンボーディングUIを使用すると、セットアッププロセスを効率化できます。現在、GitHub.comのみに対応しています。このインターフェイスにより、統合が簡素化され、プロジェクトを迅速にオンボーディングできます。詳細な手順については、GitHub Black Duck統合ドキュメントを参照してください。

- アクション統合

  その他のSCMプラットフォームについては、アクション統合により、既存のワークフローにBlack Duckを組み込むための柔軟なオプションが提供されます。GitLab SCAクイックスタートガイドなどのクイックスタートガイドを利用すれば、シームレスにスキャン環境をセットアップできます。

- Detect CLI

  Black Duck Detect CLIは、上級ユーザー向けに、ソースコード、バイナリ、コンテナをスキャンするための強力でカスタマイズ可能なツールを提供します。WindowsおよびLinux環境（Bash/PowerShellガイド）で利用可能なコマンドにより、CI/CDパイプラインへの統合をサポートしています。

- Detect Desktop

  Detect Desktopによって提供されるユーザーフレンドリーなデスクトップアプリケーションによって、コマンドライン操作なしでプロジェクトを簡単にスキャンできます。

- Code Sight IDE

  Code Sightは開発環境に直接統合され、リアルタイムのスキャンと脆弱性に関する分析情報を提供することで、開発者がコーディング中に問題を特定し、対処できるよう支援します。

注： 一部の機能では、特定のライセンスや設定が必要になる場合があります。ご自身の環境で利用できるスキャンツールがわからない場合は、管理者にお問い合わせください。

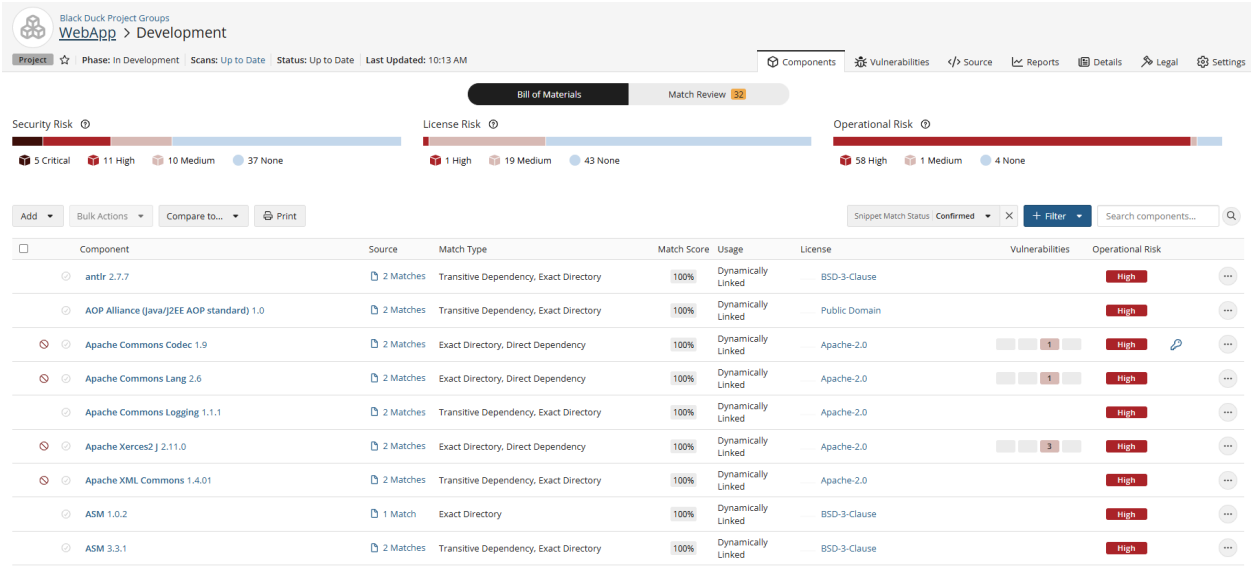
4. BOMの表示

コードベースをスキャンしてプロジェクトバージョンに結果をマッピングすると、Black DuckによってBOMが自動で生成されます。BOMには、該当するプロジェクトバージョンで検出されたすべてのオープンソースコンポーネントが、関連データ(ライセンス、脆弱性、ポリシーステータスなど)と併せて一覧表示されます。

ソフトウェアに何があるか、リスクやコンプライアンスの問題に対処する必要があるかどうかを把握するうえで、BOMは一元的なビューの役目を果たします。

BOMの表示方法

1. Black Duck SCAにログインします。
2. [ダッシュボード]で、[ウォッチ]または[マイプロジェクト]タブのいずれかを使用してプロジェクトを選択します。
3. プロジェクトページで、表示するバージョンを選択します。これで、BOMが表示されている[コンポーネント]タブにリダイレクトされます。



BOMビューについて

- BOMには、選択されているプロジェクトバージョンのオープンソースコンポーネントがすべて表示されます。
- デフォルトではフラットビューで表示されるため、コードベースに導入された方法に関係なく、単一のリストにすべてのコンポーネントが表示されます。
- 各コンポーネントエントリには重要な詳細(コンポーネントの名前とバージョン、マッチタイプ、ライセンス、セキュリティと運用上のリスクなど)が含まれています。これらのコンポーネントの特性に関する詳細については、こちらをご覧ください。

BOM内で並び替え、フィルタ、検索を行うと、リスクの高いコンポーネントやポリシーに違反しているコンポーネントに焦点を当てることができます。

BOMを利用する

- コンポーネントをクリックすると、以下を含むより詳細な情報が記載されているスライドアウトパネルが開きます。
  - 脆弱性

  - ライセンス
  - 取得元ID（例：PURL、CPE）
  - その他の詳細（説明や承認ステータスなど）
- 適切な権限がある場合は、BOMからポリシー上書きや修正アクションを直接適用できます。
- サポート対象形式（SPDXやCycloneDXなど）を使用することで、システムBOMレポートを生成できます。

さらに利用する

- BOMの詳しい利用方法については、Black Duckドキュメントのプロジェクトバージョン BOMを参照してください。
- 脆弱性の解釈方法については、セキュリティリスクを管理を参照してください。
- ポリシーの設定については、ポリシーを管理を参照してください。